

SEGURTASUN AUDITORIA

- KONFIRUGATU GABEKO EDUKIARIBURUZKO SEGURTASUN POLITIKA

>  Content Security Policy (CSP) Header Not Set (4)

Alerta hau, CSP politika ez dela aplikatu aipatzen du, zeinak ahalbidetzen du zein eduki baimenduta daude web orrian, hau da, filtratzen du zein baliabide kargatu ahal diren web orrian. CSP barik edozein script exekutatu ahal dira web orrian.

Horretarako, alerta hau konpontzeko CSP politika gehituko da zerbitzariko konfigurazioan.

- CLICKJACKING AURKAKO BABES GOIBURUA FALTAN

>  Missing Anti-clickjacking Header (2)

Alerta hau lehengoarekin lotuta dago, zerbitzariaren erantzuna ez baitago CSP ezta X-frame-Options goiburuarekin babestuta. HTTP erantzunean ez baitira aurkitzen. Horri esker, erasotzaileak ikusten ez den azal bat sortu ahal dute, non erabiltzaileak web orriarekin interakzioa izaten ari direla pentsatuz beste gauza batzuk egiten ari dira.

Horretarako HTTP erantzunetan, CSP eta X-frame-Options goiburuak gehituko dira.

- HTTPONLY FLAG GABEKO COOKIE-ak

>  Cookie No HttpOnly Flag

HttpOnly flag-a gabeko COOKIE-a aurkitu da, horri esker, COOKIE-ra, JavaScript bidez, sarbidea ezarri daiteke. Horregatik, COOKIE-a beste leku batera transmititu daiteke. HttpOnly flag-ari esker, COOKIE-ak babestuta egongo dira.

Horretarako HttpOnly flag-a COOKIE guztietara gehituko da.

- TOKEN ANTI-CSRF EZ EGOTEA

 Ausencia de Tokens Anti-CSRF (5)

Web-orriko formulario edo eskaera batzuk ez dute CSRF (Cross-Site Request Forgery) erasoen aurkako babes-tokenik. Hau konpontzeko, anti-CSRF token bat gehitu behar da eta egiaztatu zerbitzarian bidaltzen dela eskaera bakoitzean.

- SAMESITE ATRIBUTU GABEKO COOKIE-A

> Cookie sin el atributo SameSite

Webguneak ezarritako cookie batzuek ez dutela SameSite atributua zehaztuta. Hau da, SameSite atributuak cookie batek beste domeinu batetik bidalitako eskaeretan erabil daitekeen ala ez kontrolatzen du. Hau konpontzeko, cookie-a ezartzean SameSite atributua gehitu behar da eta honek babestu egiten du zure erabiltzaileen saioa beste orri batzuetatik etor daitezkeen eskaera kaltegarrien aurka.

- ZERBITZARIAK INFORMAZIOA ZABALTZEN DU

El servidor divulga información mediante un campo(s) de encabezado de respuesta HTTP ""X-Powered-By"" (5)

Zerbitzariak bere teknologiaren informazioa zabaltzen duela X-Powered-By goiburuaren bidez. Horrek erasotzaile bati pista ematen dizkio. Hau konpontzeko, X-Powered-By goiburua ezabatu behar da.

- ZERBITZARIAK INFORMAZIOA AGERIAN USTEN DU

> El servidor filtra información de versión a través del campo "Server" del encabezado de respuesta HTTP (8)

Alerta honetan, esaten da gure zerbitzariak informazioa agerian usten duela HTTP erantzunaren goiburuan, hala nola, erabiltzen ari den bertsioa eta softwarea. Informazio hori eskuratzeak aukera eman diezaieke erasotzaileei web zerbitzariak dituen beste kalte batzuk identifikatzeko.

Alerta hau konpontzeko, zerbitzariaren HTTP erantzunaren goiburuan informazio hau ez bidaltzea bermatu behar da.

- X-CONTENT-TYPE-OPTIONS

> Falta encabezado X-Content-Type-Options (6)

Anti-MIME-Sniffing X-Content-Type-Options goiburua ez da 'nosniff' hizkuntzan ezarri. Horri esker, Internet Explorer eta Chrome-ren aurreko bertsioek MIME-sniffing egiten dute erantzunaren gorputzean, eta horrek eragin dezake gorputzak erantzuna ematea eta adierazitako eduki mota ez den eduki mota gisa interpretatzea eta erakustea. Egungo bertsioek eta Firefoxetik heredadutakoek aitortutako eduki mota erabiliko dute, MIME-sniffing egin beharrean.

Alerta hau konpontzeko, ziurtatu web aplikazioak behar bezala ezartzen duela Content-Type goiburua, eta X-Content-Type-Options a 'nosniff' goiburukoa ezartzen duela webgune guztietarako.

- AUTENTIFIKAZIO-ESKAERA IDENTIFIKATUA

> Petición de Autenticación Identificada

Eskaera hori autentifikazio-eskaera gisa identifikatu da. Eskatera "Detekzio automatikoa" gisa konfiguratutako autentifikazio-metodo bat duen testuinguru batean badago, erregela horrek autentifikazioa aldatuko du, identifikatutako eskaerarekin bat etor dadin.

Alerta hau ez da konponodu behar, informazioa ematen duen alerta baita.

- SAIOA KUDEATZEKO ERANTZUN IDENTIFIKATUA

> Respuesta de Gestión de Sesión Identificada (2)

Emandako erantzunak saioa kudeatzeko token bat duela identifikatu du. 'Other Info' eremuak Header Based Session Management metodoan erabil daitezkeen goiburuko token-multzo bat dauka. Eskatera "Auto-Detect" sisteman ezarritako Session Management metodo bat duen testuinguru batean badago, arau horrek saioaren kudeaketa aldatuko du identifikatutako tokenak erabiltzeko.

lerta hau ez da konponodu behar, informazioa ematen duen alerta baita.